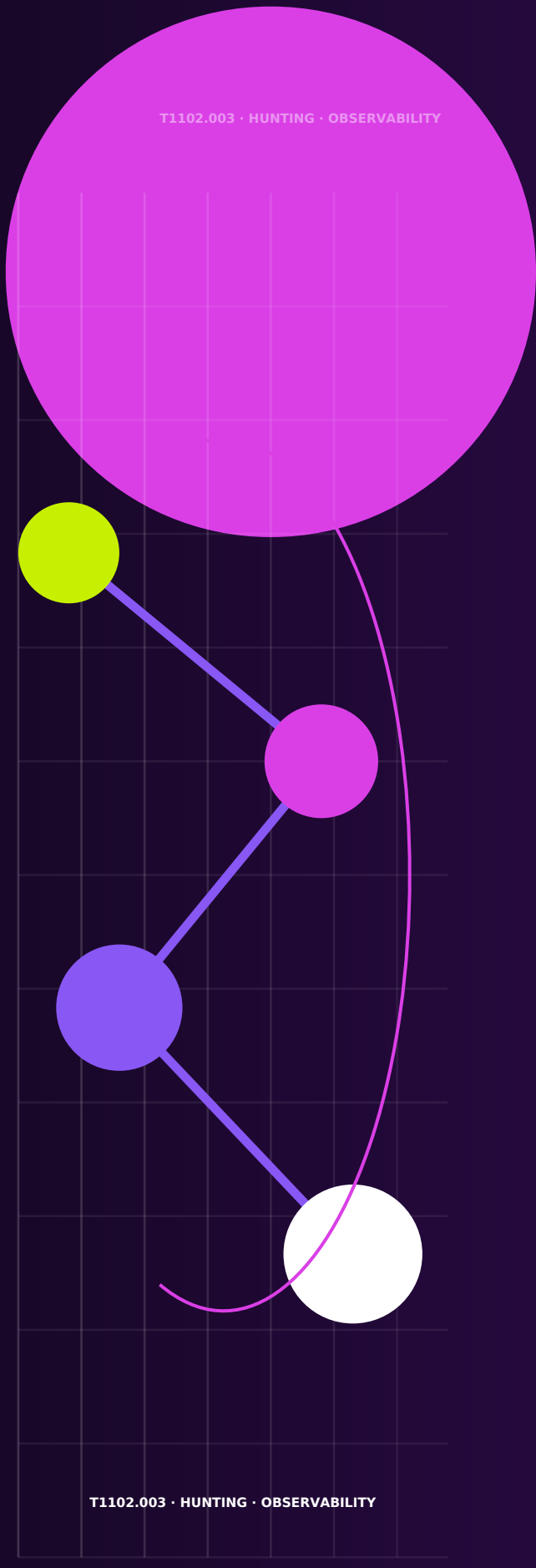
DETECTION THREAT LANDSCAPE

# CANTO INCOGNITO POELLM - POELLM GITHUB POEM C2 DISCOVERY

Hunts GitHub poem-based C2 discovery from compromised AI infrastructure.




HUNTING QUERY

CONFIDENCE: MEDIUM

REPORT TYPE
campaign

STATUS
Untested implementation sketch

PRIMARY PLATFORM
Microsoft Defender XDR

OPERATIONAL VALUE
8 / 10

01

# Executive Assessment

Decision-grade summary with explicit evidence boundaries.

ASSESSMENT

**DECISION**

Retain this package as a hunting query and migrate it to the canonical visual and evidence contract without changing query conditions. Treat every result as an investigative lead until local schema, field population, benign overlap and the legacy claim provenance are reviewed.

### LEGACY EVIDENCE RECORD

- The retained legacy source ledger contains 2 normalized references; claim-to-source mapping remains...

### ANALYST ASSESSMENT

- The existing logic is retained at hunting maturity; repository migration is not execution eviden...
- The folder and query header map the package to T1102.003; operational relevance still depend...

### DETECTION ASSUMPTIONS

- The named telemetry is collected across the intended asset or identity scope with adequate...
- Projected fields preserve their expected semantics in the target connector and parser. [C002]
- Approved activity, owners and change records are available to analysts during disposition. [C003]

## KEY FINDINGS

### FINDING 1

The original query conditions and source ledger were preserved during layout migration; legacy PDF SHA-256 62a1dcd46bf77fea... is recorded for traceability. [C001]

### FINDING 2

The principal observable is Evaluate DeviceNetworkEvents for poellm github poem c2 discovery using the existing source-derived conditions while preserving projected investigation context. [C002]

### FINDING 3

The evidence boundary remains explicit: a match does not prove Absence of results therefore does not prove absence of PoeLLM or the GitHub fetch. [C003]

**EVIDENCE BOUNDARY**

A matching result does not prove Absence of results therefore does not prove absence of PoeLLM or the GitHub fetch. Target-environment field population, benign prevalence, parser behavior and operational ownership have not been validated by this repository migration.

02

# Threat Mechanics

Technical mechanism, observable transitions and supported scope.

ATTACK FLOW

### TECHNICAL BACKGROUND

The retained dossier links Canto Incognito Poellm to the detection opportunity described as poellm github poem c2 discovery. The v2 migration preserves the query exactly and exposes its match boundary, but does not reinterpret legacy source claims as laboratory evidence. Evaluate DeviceNetworkEvents for poellm github poem c2 discovery using the existing source-derived conditions while preserving projected investigation context. [C001][C002]

1

### THREAT CONTEXT

Hunts GitHub poem-based C2 discovery from compromised AI infrastructure. Observable: Context retained from the legacy dossier and source ledger.

2

### OBSERVABLE CANDIDATE

Evaluate DeviceNetworkEvents for poellm github poem c2 discovery using the existing source-derived conditions while preserving projected investigation context. Observable: Events from DeviceNetworkEvents and projected fields.

3

### CONTEXTUAL ENRICHMENT

Resolve asset, identity, process, ownership and change context before disposition. Observable: Raw event, surrounding timeline, inventory and authorized-change evidence.

4

### DECISION GATE

Escalate only when corroborating evidence closes the documented non-claim boundary. Observable: Controlled validation, explainable negatives and analyst-readable evidence.

03

# Telemetry & Evidence Model

Minimum data contract and known visibility gaps.

DATA CONTRACT

**PRIMARY PLATFORM**

Microsoft Defender XDR. Evaluate DeviceNetworkEvents for poellm github poem c2 discovery using the existing source-derived conditions while preserving projected investigation context.

| FIELD / TABLE | STATUS | PURPOSE |
|---|---|---|
| **DeviceNetworkEvents** | **Required** | Primary event source selected by the unchanged query logic. |
| **Event time and entity identifiers** | **Required** | Chronology, deduplication, scoping and investigation pivots. |
| **Raw projected context** | **Required** | Preserve the fields emitted by the query before normalization or tuning. |
| **Asset, identity and change inventory** | **Enrichment** | Separate authorized activity and define operational ownership. |

**KNOWN VISIBILITY GAPS**

Unvalidated local schema Missing projected fields Incomplete retention or asset scope Mutable attacker behavior Legacy claim provenance review pending

04

# Primary Detection Logic

Native query, explicit condition evidence and match meaning.

KQL

```
// Rule: [T1102.003] Canto Incognito Poellm - Poellm Github Poem C2 Discovery
// MITRE ATT&CK: T1102.003
// Classification: Hunting query
// Status: Untested implementation sketch
// Primary platform: Microsoft Defender XDR
// Required telemetry: DeviceNetworkEvents
// Purpose: Hunts GitHub poem-based C2 discovery from compromised AI infrastructure.
// Logic: Evaluate DeviceNetworkEvents for poellm github poem c2 discovery using the existing source-derived conditions while preserving projected
// A match proves: A result proves that the published query conditions matched in DeviceNetworkEvents; it is an investigative event, not a maliciou
// A match does not prove: Absence of results therefore does not prove absence of PoeLLM or the GitHub fetch.
// Expected false positives: authorized administration, approved software, testing, or benign artifact collisions.
// Coverage limits: local schema, field population, retention, collection scope, and attacker variation require validation.
// Evidence claims: C001, C002, C003
//
// Canto Incognito / PoeLLM - GitHub poem-based C2 discovery
// MITRE ATT&CK: T1102.003 - Web Service: One-Way Communication
// Platform: Microsoft Defender XDR Advanced Hunting
// Status: Hunting query - Untested implementation sketch
// Confidence: Medium
// Required telemetry: Microsoft Defender for Endpoint DeviceNetworkEvents
// Evidence: Black Lotus Labs observed PoeLLM retrieving a file named dash.css
// from a GitHub repository owned by ejejejdfbbebe to derive the current C2 IP.
// Limitation: RemoteUrl may contain only an FQDN in some events. Absence of
// results therefore does not prove absence of PoeLLM or the GitHub fetch.

DeviceNetworkEvents
| where RemoteUrl has "ejejejdfbbebe"
| where RemoteUrl endswith "dash.css"
| project
    Timestamp,
    DeviceName,
    RemoteUrl,
    RemoteIP,
    RemotePort,
    Protocol,
    InitiatingProcessFileName,
    InitiatingProcessCommandLine,
    InitiatingProcessFolderPath,
    InitiatingProcessSHA1,
    InitiatingProcessAccountName,
    ReportId
| order by Timestamp desc
```

### WHAT A MATCH PROVES

A result proves that the published query conditions matched in DeviceNetworkEvents; it is an investigative event, not a malicious verdict.

### WHAT IT DOES NOT PROVE

Absence of results therefore does not prove absence of PoeLLM or the GitHub fetch.

### MATURITY

Hunting query - Untested implementation sketch. Evaluate DeviceNetworkEvents for poellm github poem c2 discovery using the existing source-derived conditions while preserving projected investigation context.

05

# Triage & Hunting Playbook

Evidence-preserving workflow from match to disposition.

WORKFLOW

**01**

Preserve the complete raw matching event, query version, timestamp, connector or sensor version and stable entity identifiers.

**02**

Confirm the event originated from the intended Microsoft Defender XDR data source and verify the semantics of every condition used by the query.

**03**

Resolve asset, identity, process, software and destination ownership against authoritative inventories and approved change records.

**04**

Build the surrounding endpoint, identity, network or appliance timeline and seek an independent evidence layer before escalation.

**05**

Classify benign overlap explicitly; tune only with durable ownership or provenance controls, never by suppressing the core behavior globally.

**06**

Escalate only when corroborating evidence establishes malicious or unauthorized activity beyond the documented match boundary.

**DISPOSITION RULE**

Escalate only when the evidence establishes the behavior described by the query. Absence of results therefore does not prove absence of PoeLLM or the GitHub fetch.

06

# False Positives & Validation

Overlap model, controlled checks and promotion gate.

QUALITY GATE

### AUTHORIZED ADMINISTRATION OR SOFTWARE

Require owner, purpose, approved change and expected execution or configuration provenance.

### BENIGN ARTIFACT OR COMMAND COLLISION

Require the full condition set plus an independent evidence layer or stable provenance.

### PARSER, INVENTORY OR RETENTION AMBIGUITY

Reproduce a controlled event and reconcile raw fields, collection scope and authoritative inventory.

## VALIDATION SEQUENCE

- Generate an authorized controlled equivalent of the primary observable without using live malicious infrastructure.
- Verify each query condition and projected field against retained raw telemetry.
- Run representative approved and near-match negative controls.
- Measure historical prevalence and classify every returned owner or workflow.
- Record parser, connector, retention and asset-scope dependencies with the test evidence.

### SUCCESS

The controlled positive produces a complete, explainable row and representative negatives are separable through durable context.

### REJECTION

Reject promotion when field semantics, collection scope, benign ownership or the core behavior cannot be established reproducibly.

### PROMOTION GATE

Require claim-level source review, a retained controlled positive, representative negatives, measured prevalence and an accountable operational owner.

07

# Analyst Assessment & References

Coverage statement, open questions and source record.

FINAL

**CONCLUSION**

This package now uses the canonical v2 layout and evidence contract while preserving the original hunting.kql conditions. It remains a hunting query at medium confidence. The visual migration is complete; claim-level provenance and target-environment execution remain explicit promotion gates.

**MITRE ATT&CK**

T1102.003

## PRIMARY AND AUTHORITATIVE REFERENCES

**S001 lumen.com - Canto incognito: tracking the PoeLLM malware (2026-10-11)**

hxxps://www[.]lumen[.]com/blog/en-us/canto-incognito-tracking-the-poellm-malware

**S002 Microsoft Learn - DeviceNetworkEvents table in the advanced hunting schema (2026-10-07)**

hxxps://learn[.]microsoft[.]com/en-us/defender-xdr/advanced-hunting-devicenetworkevents-table

**OPEN QUESTIONS**

A matching result does not prove Absence of results therefore does not prove absence of PoeLLM or the GitHub fetch. Target-environment field population, benign prevalence, parser behavior and operational ownership have not been validated by this repository migration.

**DOCUMENT CONTROL**

Schema 2.0 | Layout 2.0 | Maturity hunting | Confidence Medium | No customer data | Evidence ledger required